SEMANA 5 · SEGURIDAD Y CUMPLIMIENTO EN LA NUBE

Responsabilidad compartida y defensa en profundidad

Parte 1 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

Seguridad y cumplimiento en la nube: modelo de responsabilidad compartida, cifrado en reposo/tránsito, marcos de cumplimiento

ENCUADRE

Seguridad cierra la Unidad 1

Cada semana aportó un control; hoy los unimos en un solo sistema de defensa.

Semana 1	Semana 2	Semana 3	Semana 4	Semana 5
				
Fundamentos	**Identidad y acceso**	**Almacenamiento**	**Redes virtuales**	**Seguridad y cumplimiento**
Qué es la nube, modelos de servicio y proveedores	Usuarios, roles, MFA y mínimo privilegio	Objetos, bloques y archivos; volúmenes cifrados	VPC, subredes, Security Groups y NACL	Todo lo anterior, ahora como un sistema

El control que aportó cada semana

La base	Quién entra	El dato	Por dónde pasa	Los une
el modelo de servicio decide quién protege qué	identidad, MFA y permisos mínimos	cifrado y acceso controlado al almacenamiento	subredes privadas y reglas de tráfico	defensa en profundidad y cumplimiento

Fuente: elaboración propia con íconos de AWS Architecture Icons

RECAPITULACIÓN

Ya construiste controles sin llamarlos así

Identidad, datos y red de las semanas 2, 3 y 4 son los controles de seguridad más básicos.

Semana 2 · Identidad



¿Quién eres y qué puedes hacer?

- Usuarios, grupos y roles
- MFA en la cuenta raíz
- Mínimo privilegio

+

Semana 3 · Datos



¿El dato está protegido?

- Bucket sin acceso público
- Volúmenes cifrados
- Versionado y copias

+

Semana 4 · Red



¿Quién habla con quién?

- BD en subred privada
- Security Groups por rol
- NACL por subred

Hoy los reunimos en un marco: defensa en profundidad

Cada capa contiene el daño si la anterior falla. Lo que ya sabes hacer son las primeras capas.

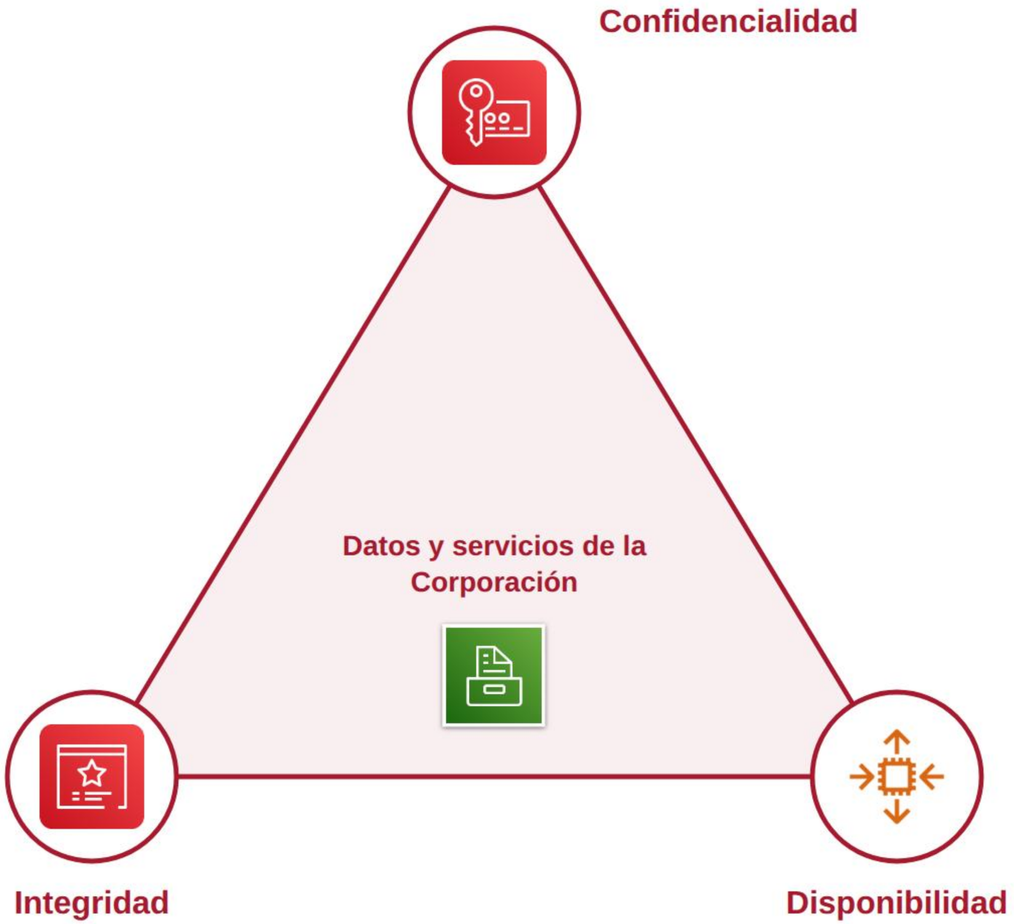
Seguridad no es un producto: es una disciplina de diseño.

Fuente: elaboración propia a partir de AWS Well-Architected, pilar de seguridad

CONCEPTO

La tríada CIA: qué protegemos

Confidencialidad, integridad y disponibilidad: toda decisión de seguridad defiende al menos una.



Confidencialidad

Solo ve el dato quien debe verlo

Amenaza: Filtración de la nómina o de fórmulas de producción

Control: IAM con mínimo privilegio + cifrado

Integridad

El dato no cambia sin dejar rastro

Amenaza: Alguien modifica el valor de una orden de compra

Control: Versionado, firmas y registros de auditoría

Disponibilidad

El sistema responde cuando se necesita

Amenaza: ERP caído en día de despacho o ataque de denegación de servicio

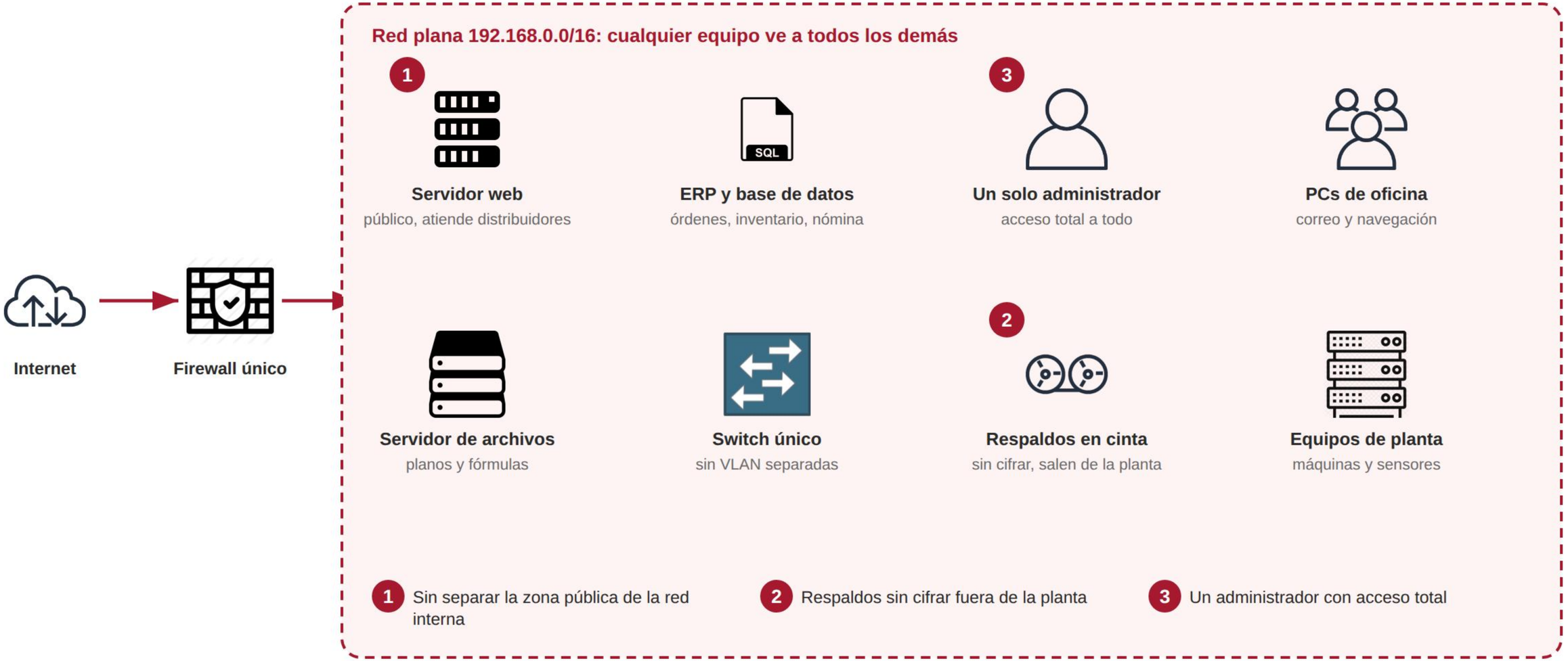
Control: Varias zonas, respaldos y protección DDoS

Fuente: adaptado de NIST SP 800-53 y AWS Well-Architected, pilar de seguridad

CASO APLICADO

Corporación Industrial del Caribe: el punto de partida

Hoy todo vive en una red plana en la planta de Barranquilla, con tres riesgos concretos.



Fuente: caso del curso (ficticio) con íconos de diagramas.net / mingrammer

CONCEPTO

Seguridad de la nube y seguridad en la nube

El proveedor asegura la infraestructura; tú aseguras lo que construyes y guardas encima.

Proveedor
de nube

SEGURIDAD DE LA NUBE · la opera y audita el proveedor

- **Centros de datos** — vigilancia, energía, enfriamiento
- **Servidores físicos** — hardware y firmware
- **Red global** — regiones, zonas y borde
- **Virtualización** — hipervisor que aísla clientes

línea de responsabilidad

Tú
el cliente

SEGURIDAD EN LA NUBE · la configuras y operas tú

- **Datos** — clasificar y proteger
- **Identidades** — quién accede y con qué permisos
- **Red virtual** — subredes y reglas de tráfico
- **Sistema y aplicación** — parches y código
- **Cifrado** — claves y políticas

Una mala configuración tuya sigue siendo tu responsabilidad, aunque la infraestructura sea impecable.

Fuente: adaptado de AWS, Modelo de responsabilidad compartida

MATRIZ

Quién asegura qué: de on-premise a SaaS

Cuanto más gestionado es el servicio, más capas asume el proveedor; datos e identidades siempre son tuyos.

Capa de responsabilidad	On-premise	IaaS	PaaS	SaaS
Datos y su clasificación	Tú	Tú	Tú	Tú
Cuentas e identidades	Tú	Tú	Tú	Tú
Aplicaciones	Tú	Tú	Tú	Proveedor
Controles de red y firewall	Tú	Tú	Compartido	Proveedor
Sistema operativo y parches	Tú	Tú	Proveedor	Proveedor
Virtualización	Tú	Proveedor	Proveedor	Proveedor
Servidores y almacenamiento físico	Tú	Proveedor	Proveedor	Proveedor
Red física	Tú	Proveedor	Proveedor	Proveedor
Centro de datos (edificio, energía)	Tú	Proveedor	Proveedor	Proveedor

Siempre tuyo en cualquier modelo: datos e identidades.

Tú · Proveedor · Compartido (según el servicio)

Fuente: adaptado de Microsoft Learn, Responsabilidad compartida en la nube

En una instancia EC2 el sistema operativo es tuyo

Con máquinas virtuales el proveedor llega hasta el hipervisor; de ahí hacia arriba, tú.



Tu lista de tareas en IaaS

1. **Parchar el sistema operativo**
   Patch Manager automatiza ventanas de parches
2. **Cerrar puertos con Security Groups**
   solo lo necesario: 443, y 22 nunca abierto al mundo
3. **Dar un rol IAM a la instancia**
   credenciales temporales, sin llaves dentro del servidor
4. **Cifrar los volúmenes EBS**
   la clave la gestiona KMS
5. **Tomar copias (snapshots)**
   y probar que se pueden restaurar

Fuente: adaptado de AWS, Modelo de responsabilidad compartida (servicios de infraestructura)

MATRIZ EN SERVICIOS

Más gestionado, menos tareas, mismos datos

De EC2 a S3 el proveedor asume más capas; la lista tuya se acorta pero nunca desaparece.

Más control y más trabajo tuyo → **Menos trabajo tuyo**

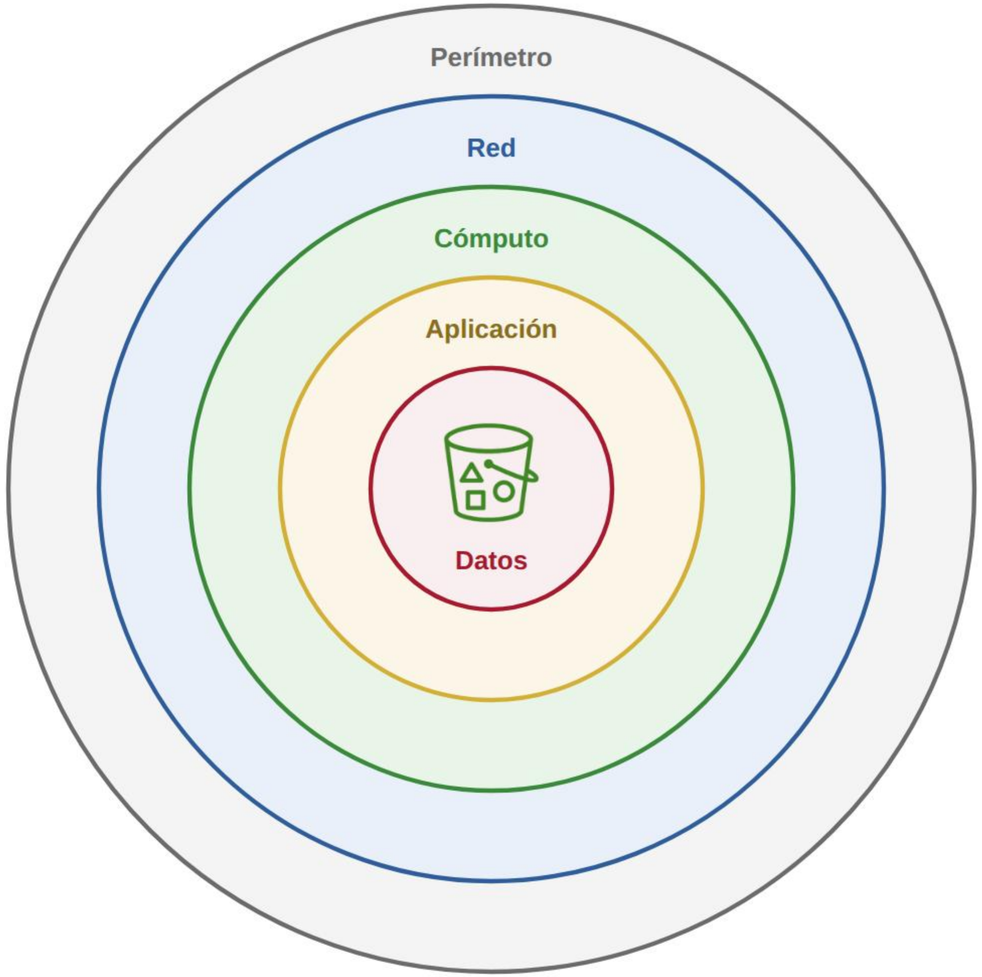
Amazon EC2	Amazon RDS	AWS Lambda	Amazon S3
AWS se encarga de • hardware y virtualización • instalaciones físicas	**AWS se encarga de** • sistema y parches del motor • respaldos automáticos • hardware	**AWS se encarga de** • servidores y escalado • sistema y runtime • alta disponibilidad	**AWS se encarga de** • infraestructura y durabilidad • disponibilidad del servicio
Tú sigues encargado de • sistema operativo y parches • aplicación y red • datos y cifrado	**Tú sigues encargado de** • usuarios y contraseñas • Security Group y cifrado • datos y esquema	**Tú sigues encargado de** • código y dependencias • permisos del rol IAM • datos que procesa	**Tú sigues encargado de** • política del bucket • acceso público y cifrado • versiones y datos

Siempre tuyos, sin importar el servicio: datos, identidades y configuración de acceso

Fuente: adaptado de AWS, Modelo de responsabilidad compartida (servicios de infraestructura, contenedor y abstractos)

Anillos de defensa: ninguna capa basta sola

Cada capa asume que la exterior ya fue vulnerada y detiene el ataque en la siguiente.



Perímetro
Centros de datos y borde: AWS Shield y WAF

Red
Subredes privadas, Security Groups y NACL

Cómputo
Parches, roles IAM y acceso sin SSH

Aplicación
Validar entradas; secretos fuera del código

Datos
Cifrado en reposo y en tránsito, copias

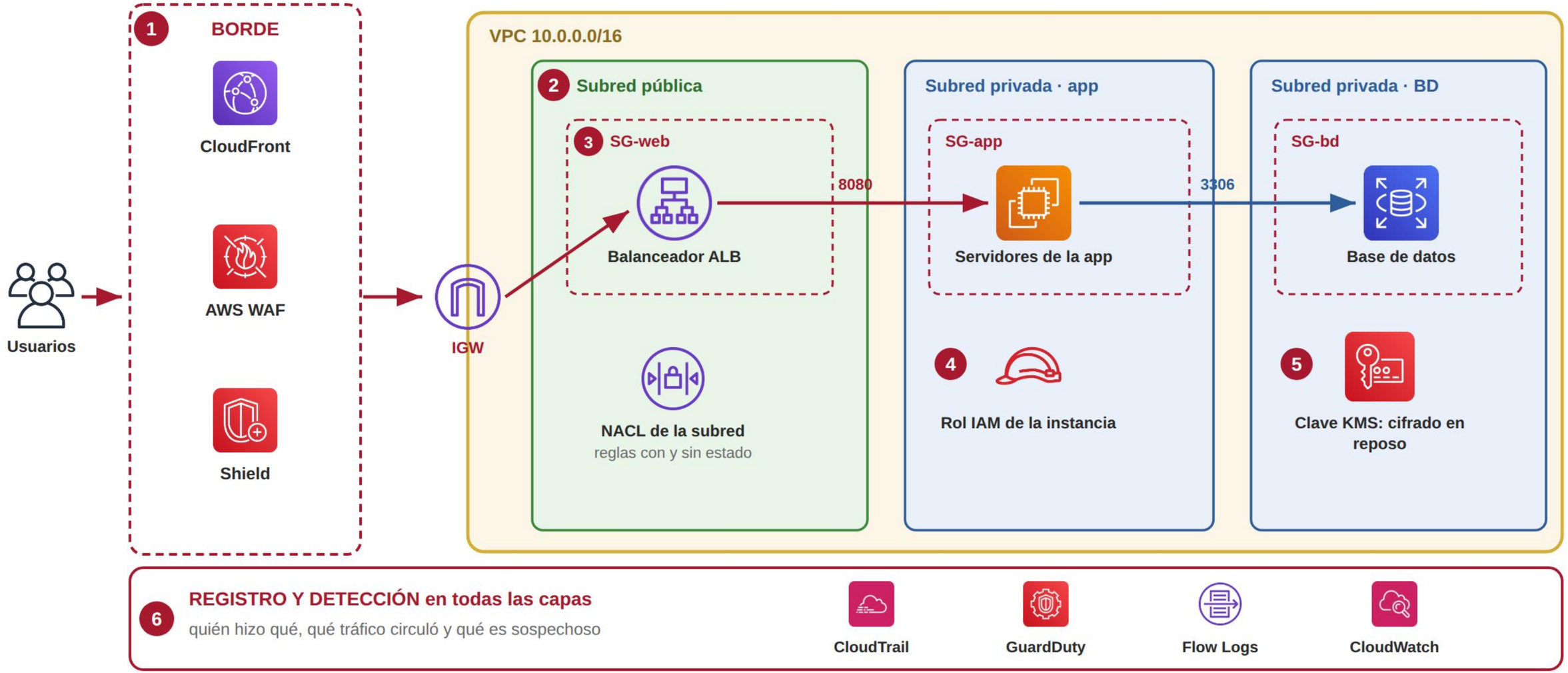
Identidad y registros atraviesan todas las capas

quién accedió y qué hizo, en cada anillo

Fuente: adaptado de Microsoft Learn, Defensa en profundidad, y AWS Well-Architected

Las capas sobre una VPC real

Seis controles se ven en una sola topología: el atacante debe vencerlos en orden.



Fuente: adaptado de AWS Architecture Center, arquitectura web de tres niveles, y AWS Security Reference Architecture

Ataques desde Internet y la capa que los detiene

Cada amenaza conocida tiene un control natural; por eso las capas no se repiten, se complementan.

Ataque	La capa que lo detiene	Resultado
Atacante — **DDoS volumétrico**: Millones de peticiones para tumbar el sitio de pedidos	**Borde: Shield + CloudFront**: Absorben el tráfico en la red global de borde	**Sitio disponible**: el tráfico basura nunca llega al origen
Atacante — **Inyección SQL y XSS**: Código malicioso escrito en un formulario web	**AWS WAF con reglas administradas**: Bloquea patrones de inyección en la capa 7	**Petición rechazada**: 403 antes de tocar la aplicación
Atacante — **Escaneo de puertos**: Busca la base de datos expuesta a Internet	**Subred privada + Security Group**: SG-bd acepta 3306 solo desde SG-app	**Sin ruta ni puerto**: la BD no es visible desde fuera
Atacante — **Fuerza bruta al acceso remoto**: Prueba miles de contraseñas contra el puerto 22	**Sin puerto 22 abierto + Session Manager**: Acceso por IAM con MFA y con registro	**Sin superficie**: no hay puerto que atacar

Fuente: adaptado de AWS Well-Architected, pilar de seguridad, y OWASP Top 10

Ataques a identidades y datos: qué capa los detiene

Las amenazas más costosas hoy no rompen la red: usan credenciales, errores de configuración o copias robadas.

	Ataque	La capa que lo detiene	Resultado
Atacante	**Phishing de credenciales** Un empleado entrega su contraseña a un sitio falso	**MFA + credenciales temporales** Roles IAM: una llave robada caduca pronto	**Acceso denegado** la contraseña sola no basta
Atacante	**Bucket público por error** Datos de clientes visibles para cualquiera en Internet	**S3 Block Public Access + Macie** Bloqueo a nivel de cuenta y detección de datos personales	**Datos privados** el error queda bloqueado
Atacante	**Ransomware o borrado** Cifran o eliminan archivos y piden rescate	**Versionado + copias aisladas** AWS Backup, bloqueo de objetos y mínimo privilegio	**Se restaura** una versión previa intacta
Atacante	**Disco o respaldo robado** Una cinta o instantánea sale de la empresa	**Cifrado en reposo con KMS** Sin la clave el contenido es ilegible	**Dato ilegible** sin clave no hay información

Fuente: adaptado de AWS Well-Architected, pilar de seguridad, y guía de AWS sobre protección contra ransomware

CASO APLICADO

Corporación Industrial del Caribe: del riesgo al control

Cada riesgo del punto de partida tiene un control equivalente en la nube.

Red plana sin segmentación

Un servidor web comprometido ve toda la red interna

migrar

Subred pública · **Subred privada** · **Security Groups**

Resultado

Separar con VPC: la base de datos nunca queda expuesta a Internet

Respaldos en cinta sin cifrar

Una cinta perdida expone años de información

migrar

AWS Backup · **Clave KMS** · **Almacén aislado**

Resultado

Copias cifradas y guardadas fuera del alcance del día a día

Un administrador con acceso total

Si su contraseña se filtra, se pierde todo

migrar

Roles · **MFA** · **CloudTrail**

Resultado

Mínimo privilegio, MFA y registro de cada acción

Fuente: caso del curso; íconos AWS Architecture Icons

Lo que queda de la Parte 1

Si recuerdas cuatro ideas, que sean estas; en la Parte 2 protegemos el dato aunque todo lo demás falle.

1



Dos mitades

La nube es del proveedor; lo que pones encima es tuyo

2



Una matriz

Más gestionado, menos tareas; datos e identidad siempre tuyos

3



Capas

Perímetro, red, cómputo, aplicación y datos, con identidad transversal

4



Sin atajos

Cada ataque se detiene en una capa distinta

Siguiente: Parte 2 · Cifrado y gestión de claves

Si todas las capas fallan, el dato debe seguir siendo ilegible.



En tránsito



En reposo



Claves



Secretos

Fuente: elaboración propia

El dato tiene tres momentos, y dos se cifran

En tránsito viaja por la red; en reposo está guardado; en uso está en memoria.

EN TRÁNSITO

el dato viaja por la red: HTTPS / TLS

EN REPOSO

el dato guardado: AES-256 con claves de KMS



EN USO · memoria

aislamiento y permisos mínimos

Regla práctica

Cifra siempre en tránsito y en reposo, y hazlo por defecto, no por excepción.

El cifrado no reemplaza al control de acceso: lo complementa cuando las demás capas fallan.

Fuente: adaptado de AWS Whitepaper, Protecting data at rest and in transit

Clave única o par de claves

La simétrica es rápida y cifra los datos; la asimétrica es lenta y permite acordar claves sin verse.

SIMÉTRICO · una clave

La misma clave cifra y descifra

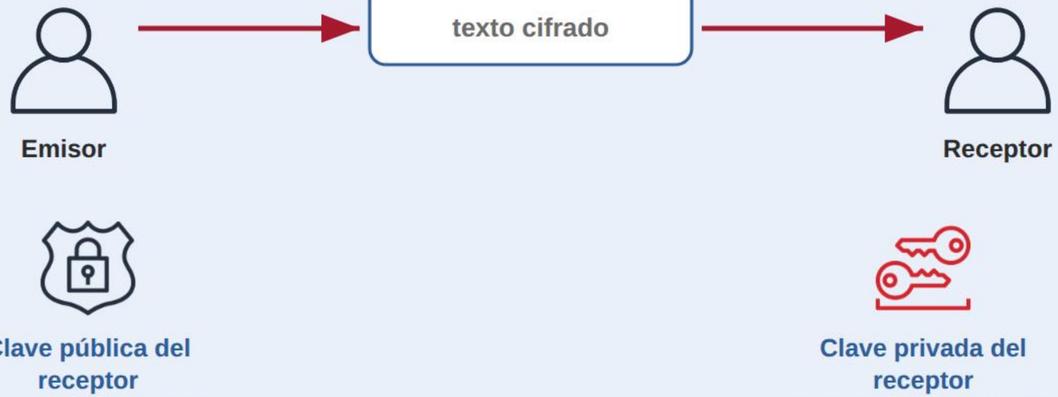


Rápido · AES-256, ChaCha20

Reto: ¿cómo entregar la clave sin que la roben?

ASIMÉTRICO · par de claves

Pública cifra; privada descifra



Lento · RSA, curvas elípticas

Resuelve el reto: nadie necesita ver la privada

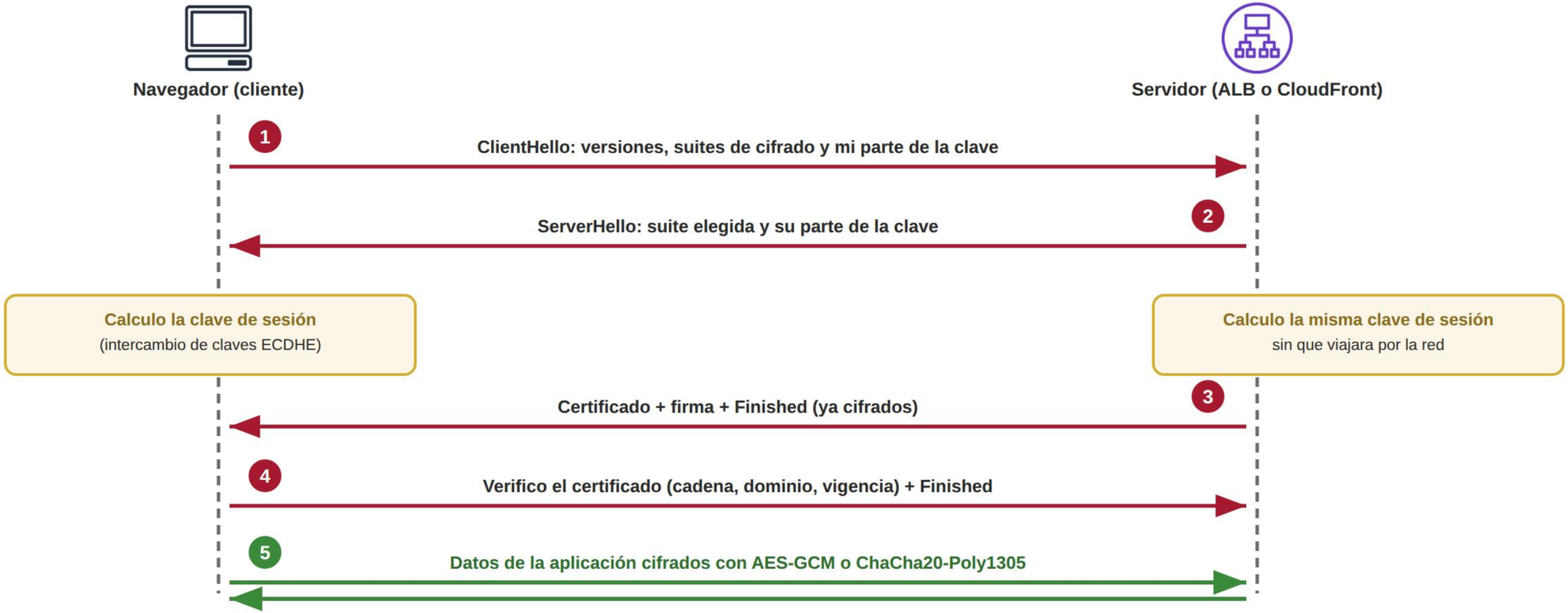
En la práctica se combinan (TLS, KMS): lo asimétrico acuerda la clave, lo simétrico cifra los datos

Asimétrico para acordar y firmar · simétrico para cifrar volúmenes grandes

Fuente: adaptado de NIST SP 800-175B, Guideline for Using Cryptographic Standards

El apretón de manos TLS 1.3, paso a paso

En un solo viaje de ida y vuelta, cliente y servidor acuerdan una clave de sesión que nadie más conoce.



1 viaje de ida y vuelta (1-RTT) · TLS 1.0 y 1.1 están retirados · mínimo recomendado hoy: TLS 1.2

Fuente: adaptado de RFC 8446 (TLS 1.3) y AWS Docs, Security policies for Application Load Balancers

Certificados: la cadena de confianza

El navegador confía en el sitio porque una autoridad que ya conoce firmó su certificado.

Autoridad raíz

Sujeto: CA raíz

Emisor: ella misma

Está en el almacén de confianza

firma al siguiente

firma

Autoridad intermedia

Sujeto: CA emisora

Emisor: CA raíz

Firma certificados de sitios

firma al siguiente

firma

Certificado del sitio

Sujeto: pedidos.ejemplo.com.co

Emisor: CA intermedia

Clave pública + vigencia + firma

sitio final

El navegador comprueba

- La firma llega a una raíz de confianza
- El dominio coincide con el sitio visitado
- El certificado no está vencido
- No ha sido revocado

Si una comprobación falla, el navegador muestra la advertencia

y la conexión no debe continuar: nunca ignores esa pantalla en producción.

Dónde se obtienen

AWS Certificate Manager
públicos para ALB y CloudFront, renovación automática

Let's Encrypt
autoridad gratuita con emisión automatizada

Vigencias cortas: automatiza la renovación

Fuente: adaptado de AWS Certificate Manager, guía del usuario, y RFC 5280

SEMANA 5 · SEGURIDAD Y CUMPLIMIENTO EN LA NUBE

Cifrado, claves y secretos

Parte 2 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes

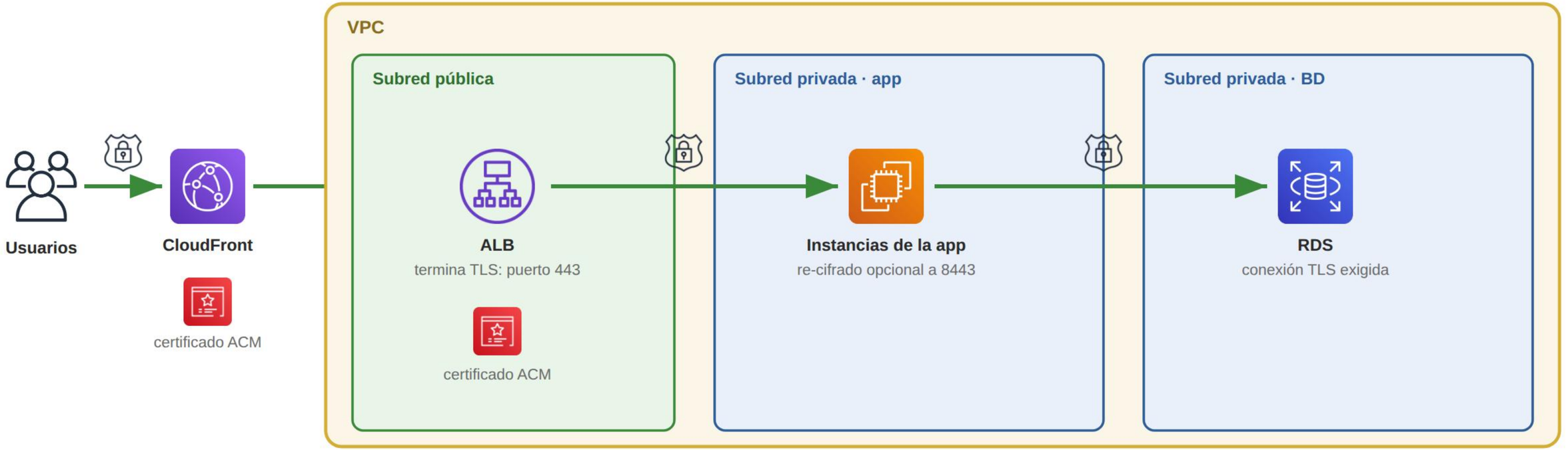
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

TLS e IPsec, AES-256, cifrado en S3, KMS y envelope encryption, y secretos fuera del código

TLS en una arquitectura AWS: dónde termina

El cifrado se extiende hasta la base de datos si lo configuras en cada tramo.



1 Redirigir HTTP a HTTPS

el puerto 80 solo responde con redirección al 443

2 TLS 1.2 como mínimo

y 1.3 donde el cliente lo permita; política de seguridad del ALB

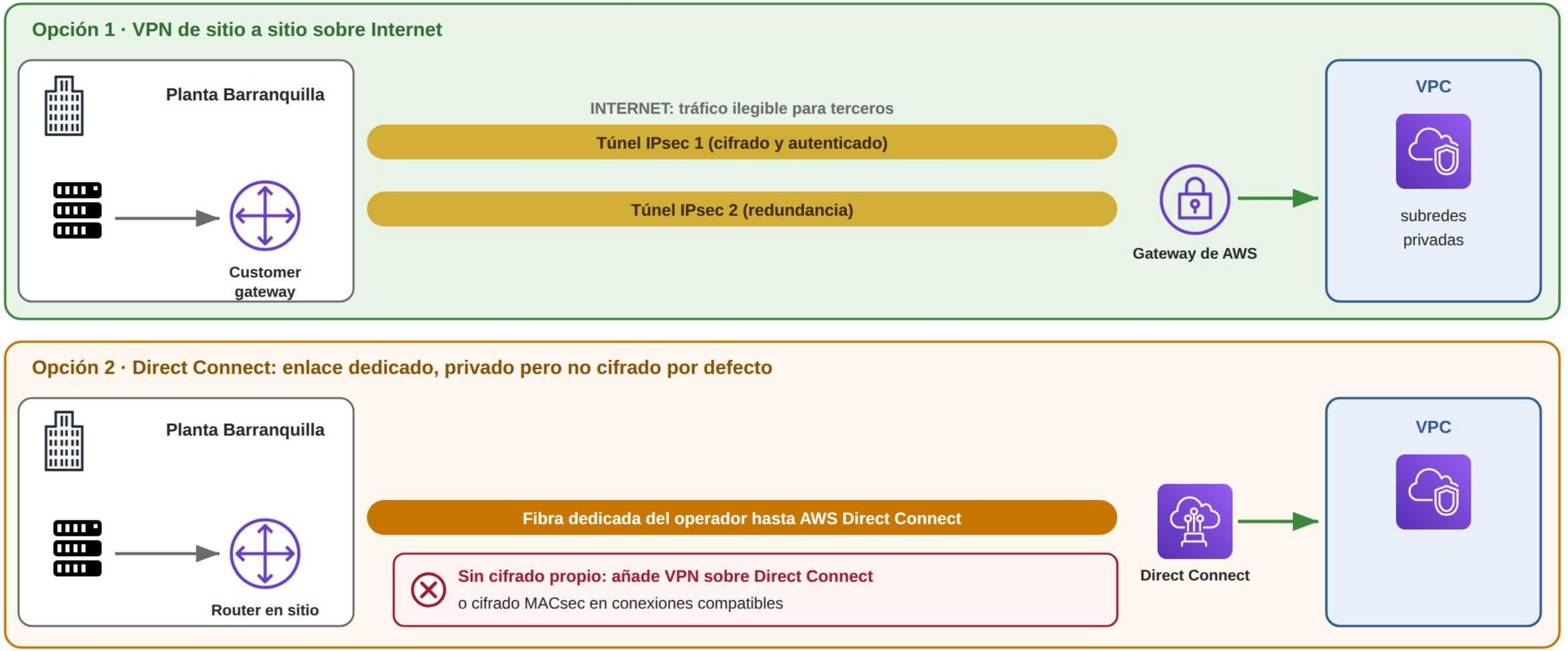
3 S3: negar transporte inseguro

condición aws:SecureTransport igual a false en la política del bucket

Fuente: adaptado de AWS Docs: ALB HTTPS listeners, CloudFront y Amazon RDS SSL/TLS

De la planta a la nube: VPN IPsec

Internet no es de confianza: el túnel IPsec cifra todo lo que cruza entre la planta y la VPC.



Fuente: adaptado de AWS Docs, Site-to-Site VPN y AWS Direct Connect (MACsec)

AES-256: de texto legible a ilegible

El mismo algoritmo protege discos, buckets y copias; quien robe el medio no obtiene información.



Dónde lo aplica AWS

Amazon S3
objetos nuevos cifrados por defecto (SSE-S3)

Amazon EBS
cifrado por defecto activable por región

Amazon RDS
se elige al crear; cubre copias y réplicas

Amazon EFS
se activa al crear el sistema de archivos

DynamoDB
siempre cifrada en reposo

Transparente para la aplicación: se cifra al escribir y se descifra al leer, solo para identidades autorizadas.

Fuente: adaptado de FIPS 197 (NIST, AES) y AWS Docs, cifrado de EBS, RDS y S3

Cuatro formas de cifrar en S3

La diferencia no está en el algoritmo sino en quién cifra y quién guarda la clave.

SSE-S3

S3 cifra y administra la clave



Quién cifra: S3

Quién guarda la clave:

S3 (administrada)

Cuándo: por defecto, datos de bajo riesgo

SSE-KMS

S3 cifra; la clave vive en KMS



Quién cifra: S3

Quién guarda la clave:

KMS (tu política)

Cuándo: datos sensibles con auditoría

SSE-C

S3 cifra con la clave que tú envías



Quién cifra: S3

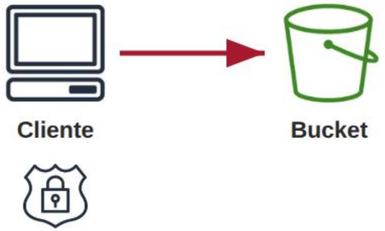
Quién guarda la clave:

tú (en cada solicitud)

Cuándo: cumples reglas muy estrictas de custodia

Del lado del cliente

Tú cifras antes de subir



Quién cifra: tu aplicación

Quién guarda la clave:

tu llavero local

Cuándo: el proveedor no debe ver nunca el dato en claro

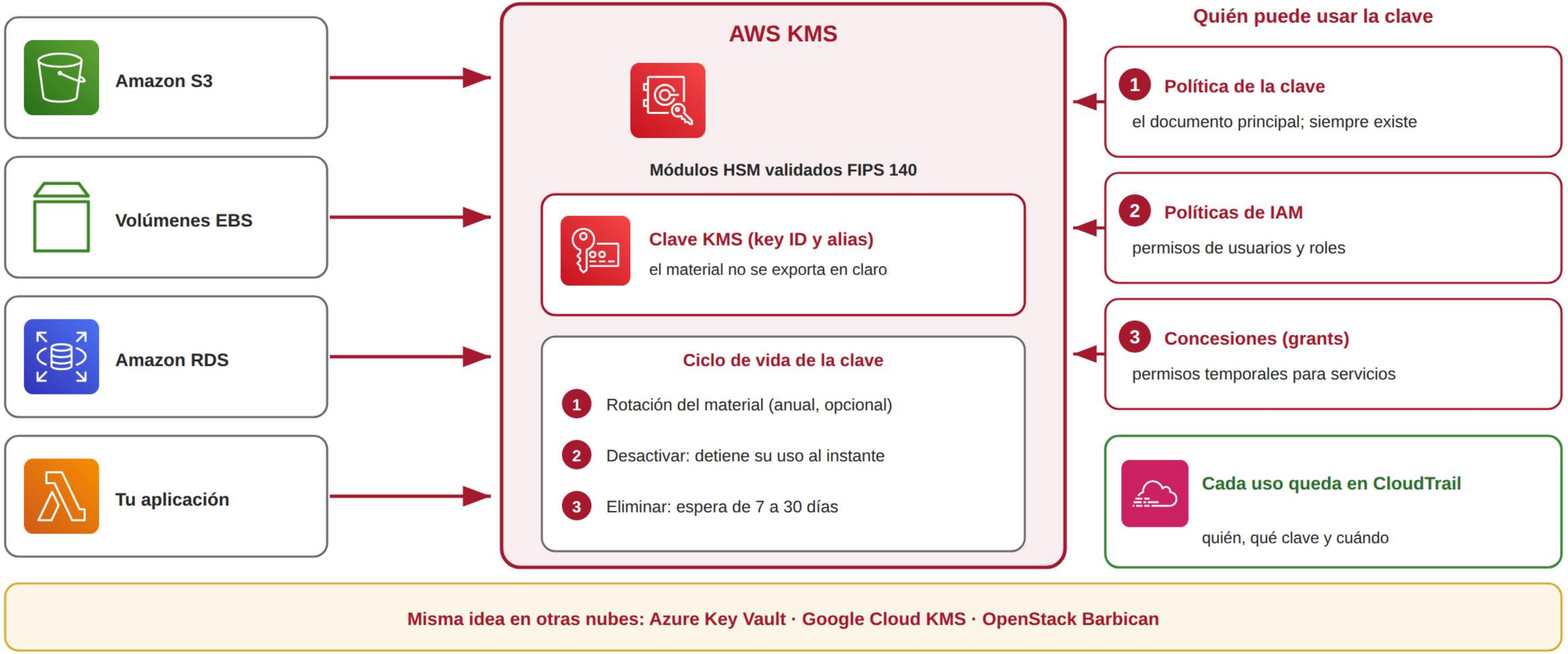
Menos control · menos trabajo → **Más control · más responsabilidad**

La opción habitual en datos corporativos: SSE-KMS con clave administrada por el cliente

Fuente: adaptado de AWS Docs, Protecting data with encryption (Amazon S3)

KMS: la caja fuerte de las claves

La clave nunca sale de KMS sin protección: los servicios le piden operar, no se la llevan.

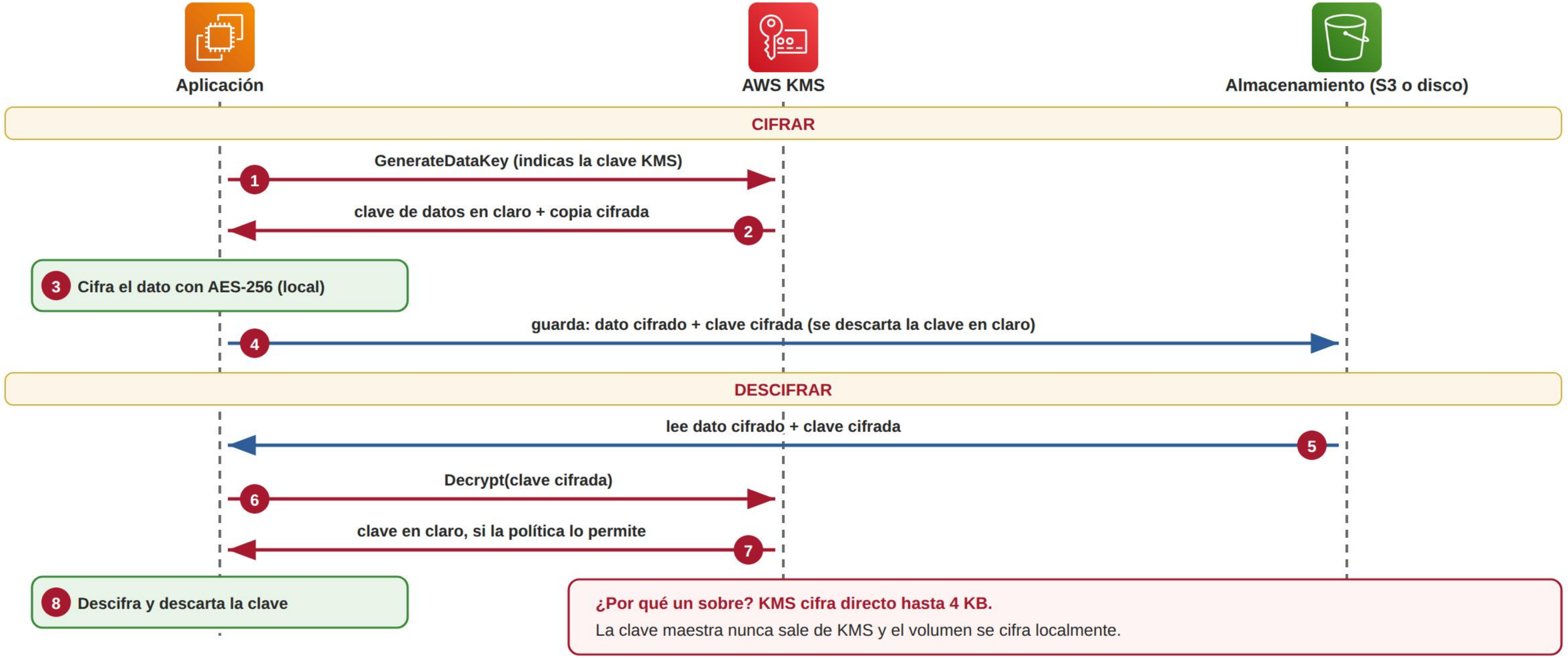


Misma idea en otras nubes: Azure Key Vault · Google Cloud KMS · OpenStack Barbican

Fuente: adaptado de AWS Key Management Service, Developer Guide (conceptos)

Cifrado de sobre (envelope encryption)

Una clave de datos cifra el dato; la clave de KMS cifra esa clave de datos: así crece sin cargar a KMS.



Fuente: adaptado de AWS KMS, Developer Guide: Envelope encryption

Claves del proveedor o claves del cliente

Más control sobre la clave significa más responsabilidad para ti: elige según la sensibilidad del dato.

Propiedad de AWS

invisible en tu cuenta

- la usan servicios como DynamoDB por defecto
- sin costo ni gestión
- sin control tuyo sobre la política



Administrada por AWS

alias aws/s3, aws/ebs

- visible en tu cuenta
- rotación automática
- política fija: no la cambias



Administrada por el cliente

tu clave KMS

- tú defines la política y los permisos
- rotación, desactivar y eliminar
- cada uso queda auditado



Material propio

BYOK, almacén externo, CloudHSM

- traes o custodias el material
- máximo control
- si lo pierdes, nadie lo recupera



Más control

Key Vault **Cloud KMS** **Barbican**

Más responsabilidad operativa

Fuente: adaptado de AWS KMS, Developer Guide: AWS owned keys, AWS managed keys, customer managed keys

Secretos: contraseñas y llaves fuera del código

Un secreto en el repositorio es un secreto publicado; se entrega en tiempo de ejecución y se rota.

Mal: el secreto va en el código

repositorio Git
visible para todos los que lo clonan

```
# config.py
DB_HOST = "bd.interna"
DB_USER = "admin"
DB_PASSWORD = "Caribe2026!"
AWS_SECRET_KEY = "wJal..."
```

Consecuencias

- Queda en el historial para siempre
- Se copia a cada portátil y servidor
- Nadie sabe quién la usó ni cuándo
- Cambiarla exige redesplegar

Bien: el secreto se entrega en tiempo de ejecución



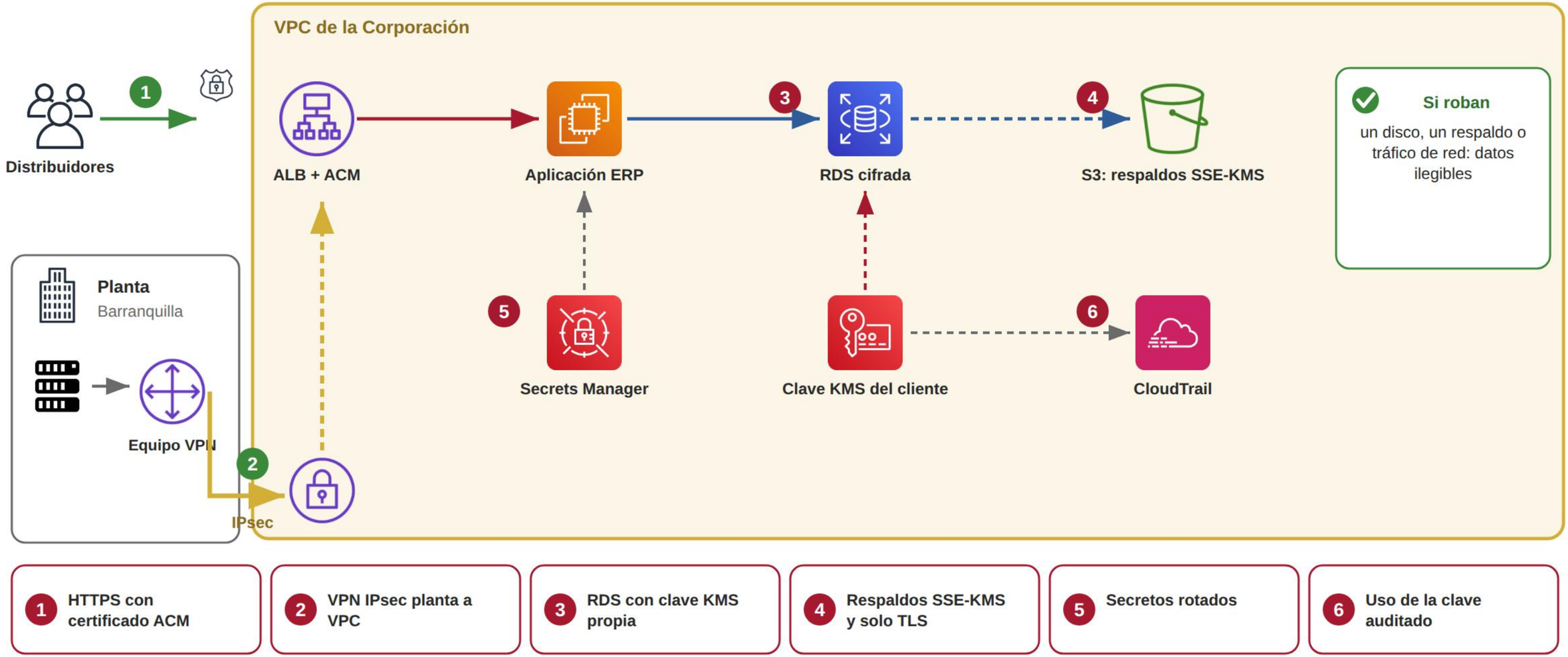
Equivalentes: HashiCorp Vault · Azure Key Vault · Google Secret Manager. Parameter Store guarda configuración; no es para rotar secretos.

Fuente: adaptado de AWS Secrets Manager, guía del usuario (rotación), y OWASP Secrets Management Cheat Sheet

CASO APLICADO

Corporación Industrial del Caribe: todo cifrado

Seis decisiones de cifrado cubren el viaje del dato, su reposo y las llaves de la migración.



Fuente: caso del curso; adaptado de AWS Architecture Center, arquitecturas de referencia con cifrado de extremo a extremo

Lo que queda de la Parte 2

Cifra el dato en cada tramo, cuida las llaves como un tesoro y saca los secretos del código.

1



En tránsito

TLS en cada tramo, certificados y VPN IPsec hacia la planta

2



En reposo

AES-256 en discos, buckets y copias

3



Claves

KMS, cifrado de sobre y claves del cliente

4



Secretos

Fuera del código, con rol y rotación automática

Siguiente: Parte 3 · Visibilidad y protección

Cifrar no basta si no te enteras de lo que ocurre: registrar, alertar, detectar y filtrar.



Auditoría



Detección



WAF y DDoS

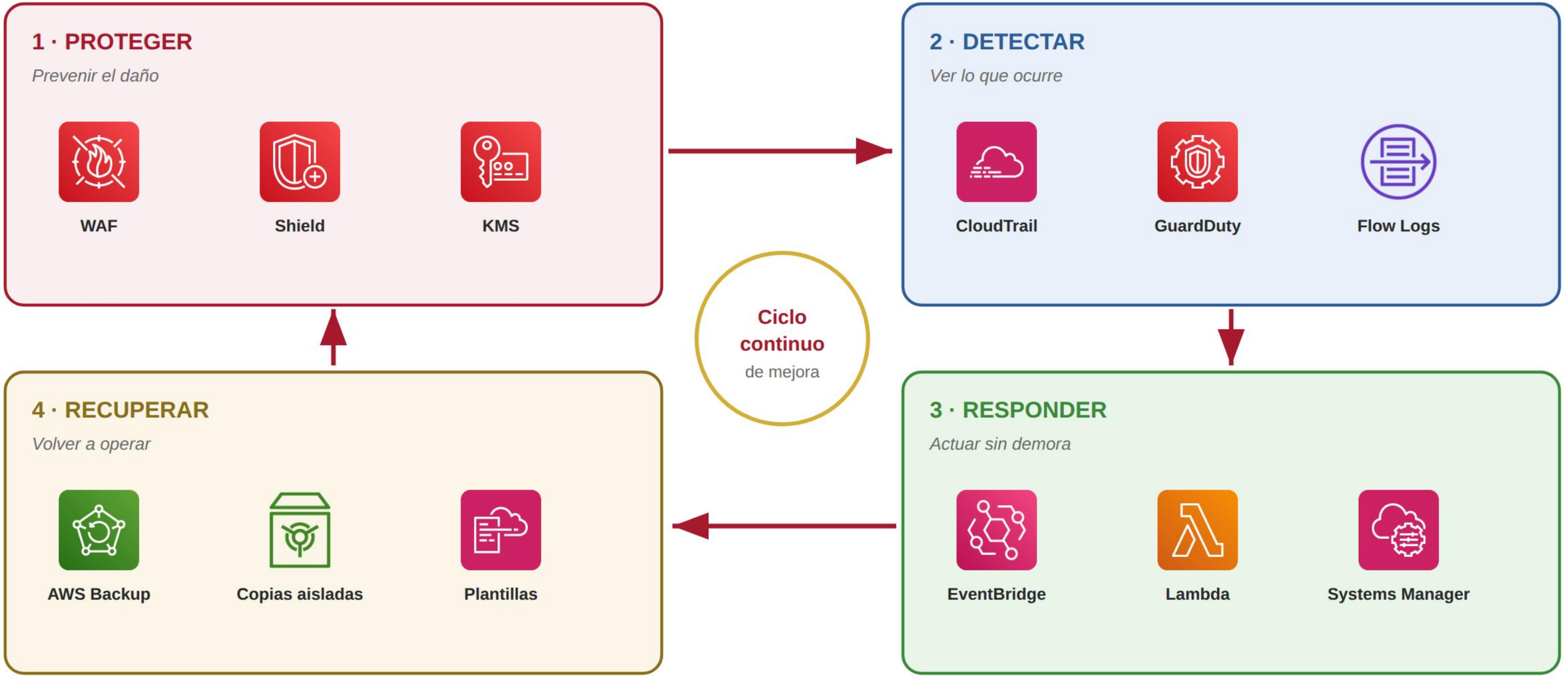


Postura

Fuente: elaboración propia

Proteger, detectar, responder y recuperar

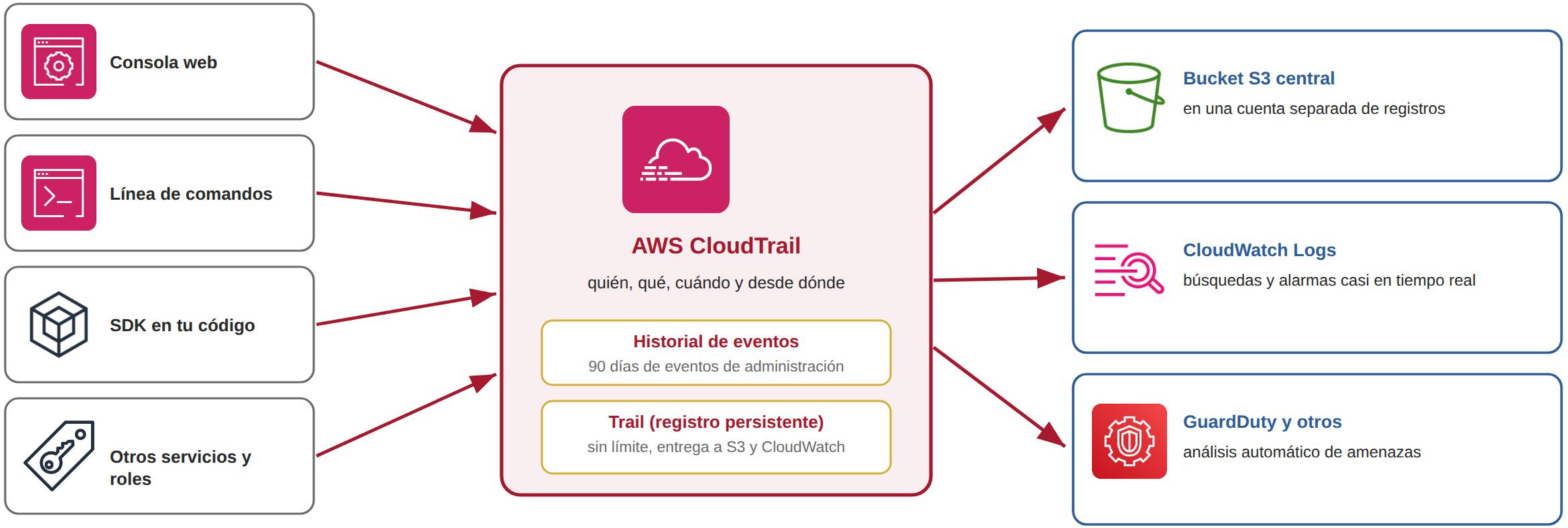
No puedes proteger lo que no ves: la seguridad es un ciclo continuo, no una instalación única.



Fuente: adaptado de NIST Cybersecurity Framework 2.0 y AWS Security Incident Response Guide

CloudTrail: el libro de actas de tu cuenta

Cada llamada a la API de AWS queda registrada: consola, línea de comandos, SDK y otros servicios.



Eventos de administración
crear, modificar o borrar recursos (activos por defecto)

Eventos de datos
leer o escribir objetos S3 e invocar Lambda (se activan aparte)

Eventos Insights
avisan de actividad inusual en las llamadas

Fuente: adaptado de AWS CloudTrail, guía del usuario, y AWS Security Reference Architecture

Anatomía de un evento: ¿quién apagó el servidor?

Un solo registro responde las preguntas de una investigación: quién, qué, cuándo, desde dónde y sobre qué.

Evento de CloudTrail (simplificado)

```
{
"eventTime": "2026-09-01T09:42:17Z",                                  1
"eventSource": "ec2.amazonaws.com",                                   2
"eventName": "TerminateInstances",                                    3
"userIdentity": {
   "type": "IAMUser",
   "userName": "operador-planta" },                                   4
"sourceIPAddress": "203.0.113.25",                                    5
"awsRegion": "us-east-1",
"requestParameters": { "instanceId": "i-0abc1234" }                   6
}
```

Qué responde cada campo

1	CUÁNDO	la hora exacta del evento
2	QUÉ SERVICIO	y qué acción pidió
3	QUÉ HIZO	apagar instancias
4	QUIÉN	usuario o rol que actuó
5	DESDE DÓNDE	dirección IP de origen
6	SOBRE QUÉ	el recurso afectado

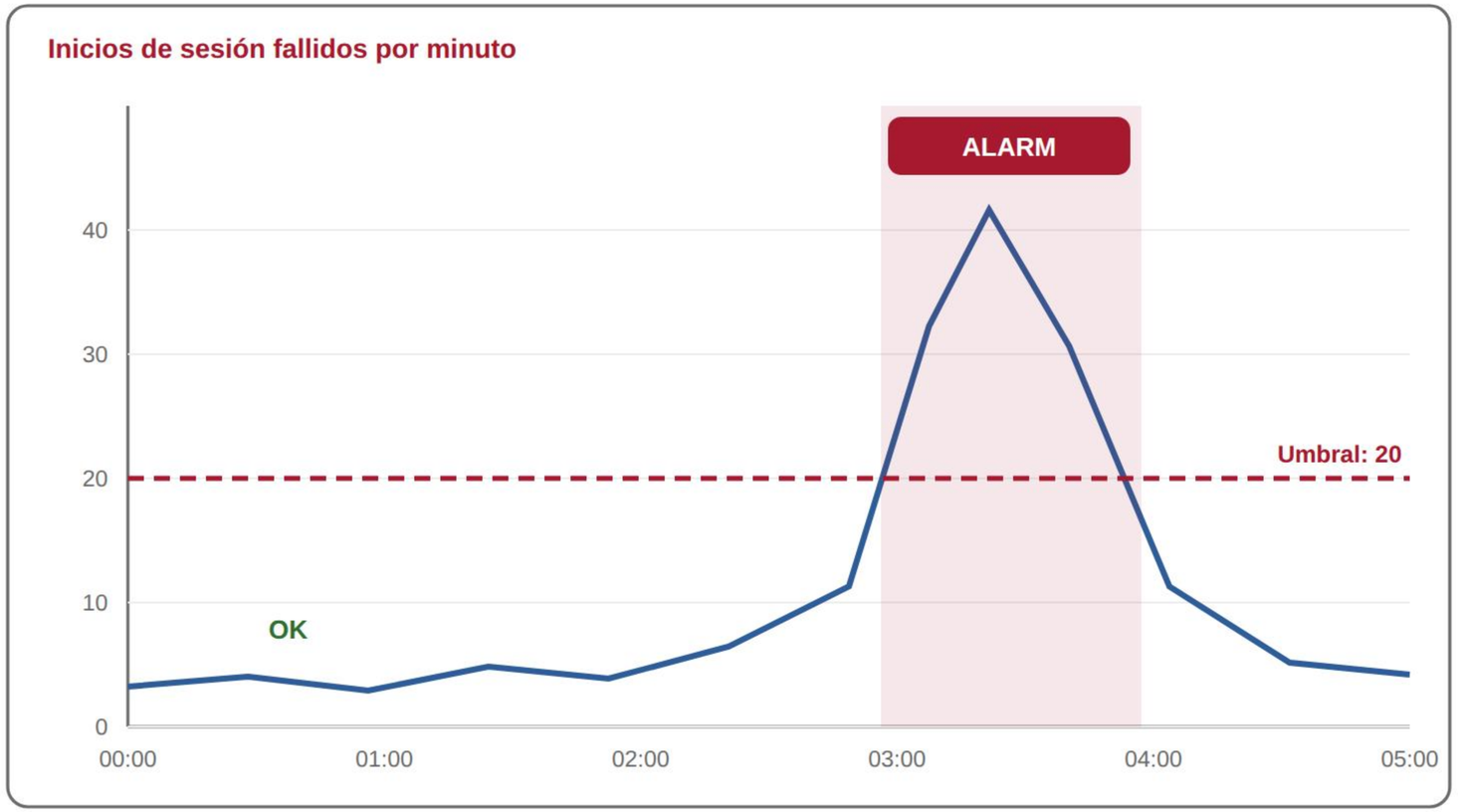
! Siguiente paso de la investigación

Filtra por userName y revisa qué más hizo en esa hora; si la cuenta fue comprometida, desactiva sus credenciales.

Fuente: adaptado de AWS CloudTrail, guía del usuario: contenido de los registros (ejemplo con IP de documentación)

CloudWatch: de la métrica a la alarma

Una métrica que cruza un umbral dispara una alarma, y la alarma avisa a las personas correctas.



¿De dónde sale la métrica? De un filtro sobre los registros de CloudTrail en CloudWatch Logs

Ejemplo recomendado: avisar cada vez que se use la cuenta raíz.

Alarma

OK, ALARM o datos insuficientes

Tema de SNS

publica el mensaje de aviso

Equipo de seguridad

correo, SMS o chat

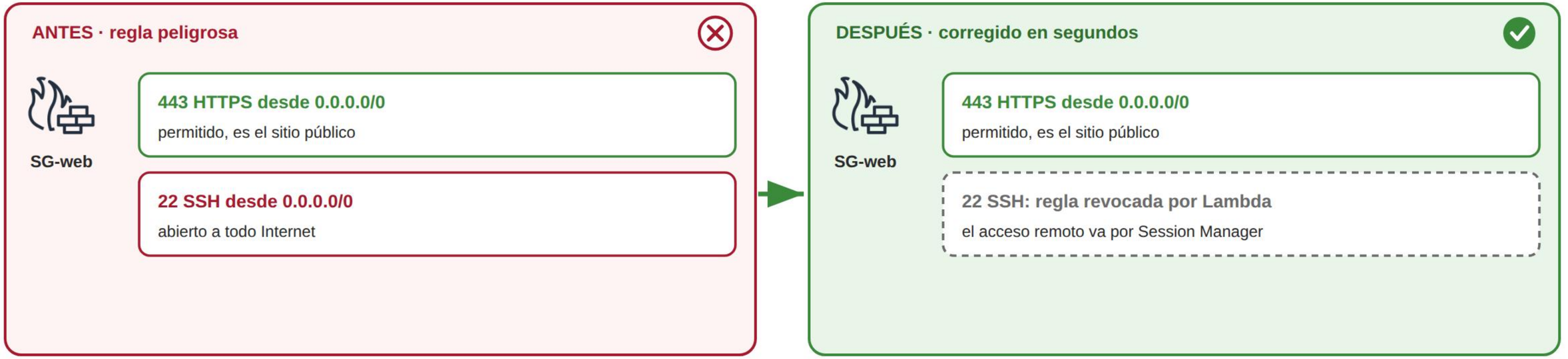
Fuente: adaptado de Amazon CloudWatch, guía del usuario (alarmas y filtros de métricas)

De la alerta a la acción: EventBridge y Lambda

Una regla puede avisar y corregir en segundos, sin esperar a que alguien despierte.



El Security Group, antes y después



Fuente: adaptado de AWS Security Incident Response Guide y Amazon EventBridge, guía del usuario

VPC Flow Logs: quién habló con quién

Registran metadatos de cada conexión aceptada o rechazada, útiles para investigar y validar reglas.



Un registro de ejemplo, campo por campo

versión	cuenta	interfaz	origen	destino	puerto origen
2	123456789012	eni-0a1b2c	198.51.100.7	10.0.1.25	44213

puerto destino	protocolo	paquetes	bytes	acción	estado
22	6 (TCP)	3	180	REJECT	OK

Lectura: una IP externa intentó entrar por SSH (puerto 22) y el Security Group la rechazó.

Registra metadatos, no el contenido de los paquetes. Sirve para análisis posterior y alimenta a GuardDuty.

Fuente: adaptado de AWS Docs, VPC Flow Logs (formato de registro predeterminado, IP de documentación)

GuardDuty: un analista que nunca duerme

Analiza tus registros con inteligencia de amenazas y aprendizaje automático, y te entrega hallazgos priorizados.



Fuente: adaptado de Amazon GuardDuty, guía del usuario (fuentes de datos y tipos de hallazgos)

Otros vigilantes: Inspector, Macie, Config y Access Analyzer

Cada servicio responde una pregunta distinta sobre tu superficie de riesgo.



Amazon Inspector

¿Mis cargas tienen vulnerabilidades conocidas?

EC2, imágenes de contenedores y funciones Lambda, con prioridad por riesgo

Ejemplo: un paquete del servidor web con una falla publicada.



Amazon Macie

¿Hay datos personales donde no deberían?

Examina buckets de S3 y detecta cédulas, tarjetas y credenciales

Ejemplo: una hoja de nómina en un bucket de pruebas.



AWS Config

¿Mis recursos cumplen las reglas?

Guarda el historial de configuración y evalúa reglas de cumplimiento

Ejemplo: un volumen EBS sin cifrar.



IAM Access Analyzer

¿Quién externo puede acceder a mis recursos?

Detecta recursos compartidos fuera de tu cuenta u organización

Ejemplo: un bucket compartido con una cuenta desconocida.

Fuente: adaptado de la documentación de Amazon Inspector, Macie, AWS Config e IAM Access Analyzer

AWS WAF: el filtro de la capa de aplicación

Inspecciona cada petición HTTP y bloquea la inyección, los bots y los abusos antes de tocar tu aplicación.

GET /pedido?id=1001
pedido normal

GET /pedido?id=1 OR 1=1
inyección de SQL

4.000 peticiones por minuto
bot desde una sola IP

Web ACL de AWS WAF

reglas evaluadas en orden

1. **Listas de reputación de IP**
   bloquea direcciones con mala fama
2. **Reglas administradas (Core)**
   inyección SQL, XSS y entradas conocidas
3. **Límite de velocidad por IP**
   frena bots y abusos
4. **Filtro geográfico**
   solo los países donde operas

Acción: permitir · bloquear · contar · desafío CAPTCHA

Se asocia a CloudFront, ALB o API Gateway

Permitido



llega a la aplicación

Bloqueado

403 Forbidden

la aplicación ni se entera

queda en el registro de WAF

Fuente: adaptado de AWS WAF, guía del desarrollador, y OWASP Top 10

SEMANA 5 · SEGURIDAD Y CUMPLIMIENTO EN LA NUBE

Defensa, cumplimiento y evidencia

Parte 3 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes

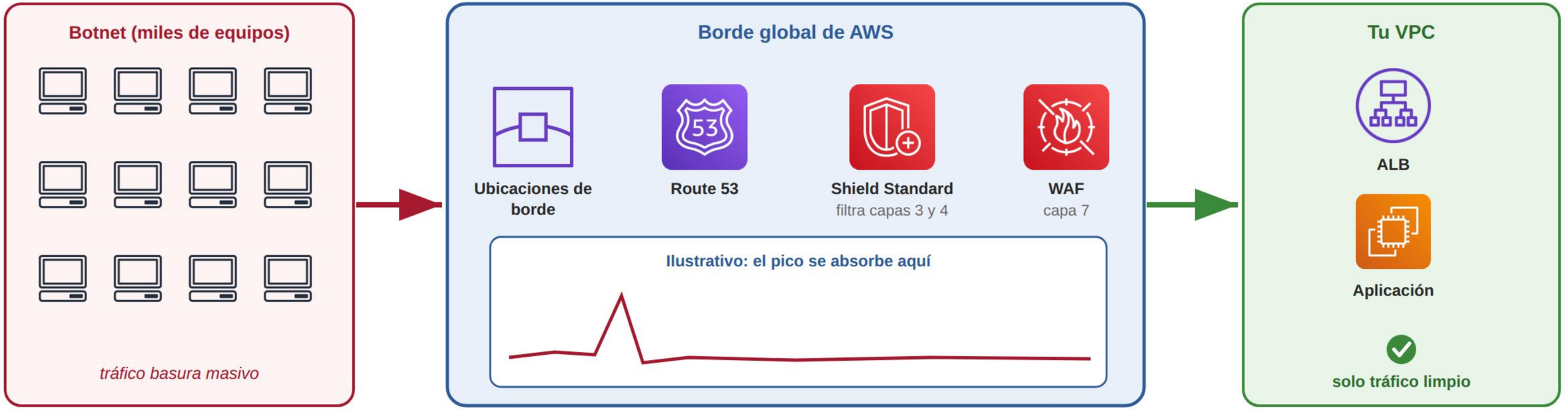
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

DDoS y Security Hub, el pilar de seguridad, ISO 27001, SOC 2, PCI DSS, evidencia del proveedor y la Ley 1581

DDoS: absorber el ataque antes del origen

La red global de borde reparte y filtra la avalancha; tu VPC recibe solo tráfico limpio.



Shield Standard — incluido en todas las cuentas

- Protección automática contra ataques comunes de red y transporte
- Sin costo adicional ni configuración
- Mejor aún detrás de CloudFront y Route 53

Shield Advanced — suscripción de pago

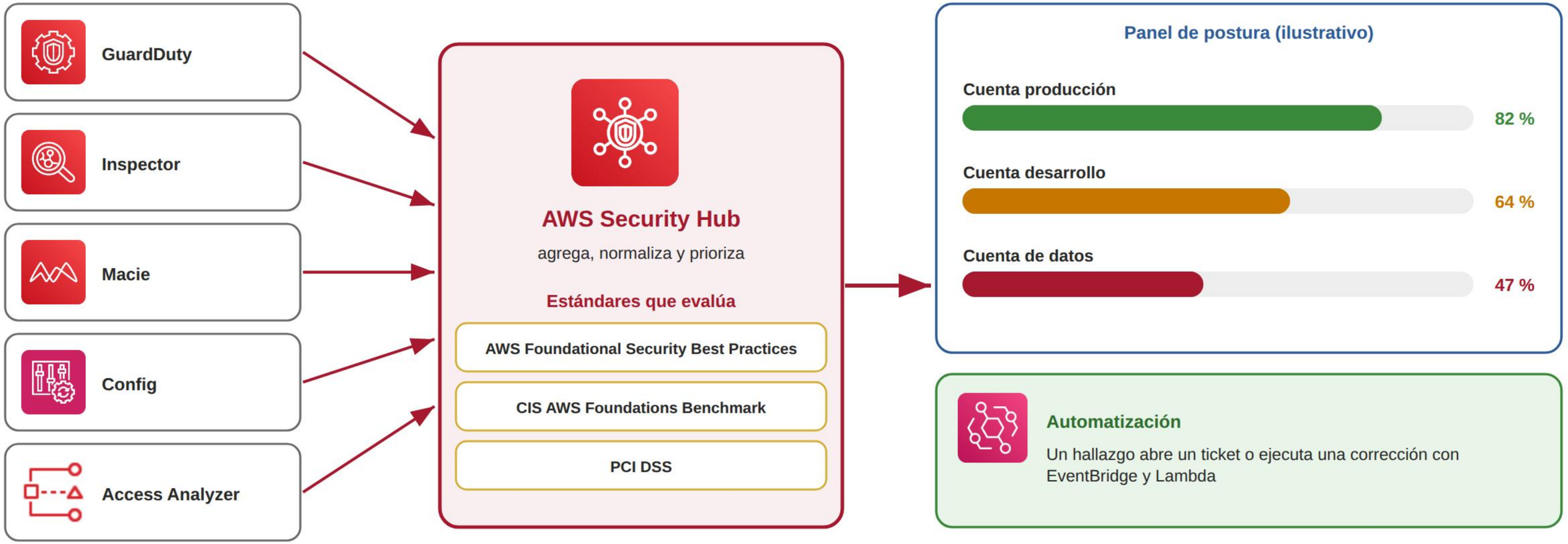
- Detección y mitigación más finas, y visibilidad de ataques
- Respuesta del equipo especializado de AWS (SRT)
- Protección de costos ante picos causados por el ataque

Fuente: adaptado de AWS Best Practices for DDoS Resiliency y AWS Shield, guía del desarrollador

POSTURA CENTRALIZADA

Security Hub: un solo tablero de seguridad

Reúne los hallazgos de todos los servicios y cuentas y los mide contra estándares reconocidos.



Con AWS Organizations, una cuenta de seguridad administra todas las cuentas de la empresa

Equivalentes: Microsoft Defender for Cloud (Azure) · Security Command Center (Google Cloud)

Fuente: adaptado de AWS Security Hub, guía del usuario, y AWS Security Reference Architecture

El pilar de seguridad de Well-Architected

El marco de seis pilares dedica siete áreas de buenas prácticas a la seguridad; hoy recorrimos casi todas.

Excelencia operativa | **Seguridad** | Fiabilidad | Eficiencia de desempeño | Optimización de costos | Sostenibilidad

Las siete áreas del pilar de seguridad

1 — Fundamentos
cuentas separadas y modelo compartido
Sem. 1 y 5

2 — Identidad y acceso
mínimo privilegio y MFA
Sem. 2

3 — Detección
CloudTrail, GuardDuty y alarmas
Parte 3

4 — Protección de infraestructura
VPC, SG, WAF y Shield
Sem. 4 y Parte 3

5 — Protección de datos
cifrado y claves
Parte 2

6 — Respuesta a incidentes
automatizar y practicar
Parte 3

7 — Seguridad de aplicaciones
parches y escaneo de código
Parte 3

Well-Architected Tool
revisión guiada de tu arquitectura

Fuente: adaptado de AWS Well-Architected Framework, Security Pillar

CASO APLICADO

Corporación Industrial del Caribe: una madrugada con alerta

La visibilidad convierte un ataque nocturno en un incidente contenido en minutos.



Cómo se organiza en varias cuentas



Fuente: caso del curso (escenario ilustrativo); adaptado de AWS Security Reference Architecture

Lo que queda de la Parte 3

Registrar, alertar, detectar y filtrar: la seguridad que no se ve no se puede defender.

1



Registrar

CloudTrail en una cuenta aparte; Flow Logs para la red

2



Alertar y responder

Alarmas, EventBridge y Lambda para corregir en segundos

3



Detectar

GuardDuty, Inspector, Macie, Config y Access Analyzer

4



Filtrar y centralizar

WAF, Shield y Security Hub con estándares

Siguiente: Parte 3 · Cumplimiento y cierre de la Unidad 1

Los auditores y la ley preguntan lo mismo: ¿puedes demostrarlo?



ISO 27001, SOC 2



PCI DSS



Ley 1581 y SIC



Región y datos

Fuente: elaboración propia

ENCUADRE

Cumplir no es lo mismo que estar seguro

Hay reglas obligatorias, estándares voluntarios y contratos; las tres cosas se prueban con evidencia.

Marcos contractuales y de auditoría

SOC 2 · PCI DSS

los piden clientes, bancos y marcas de tarjetas

Estándares y certificaciones voluntarios

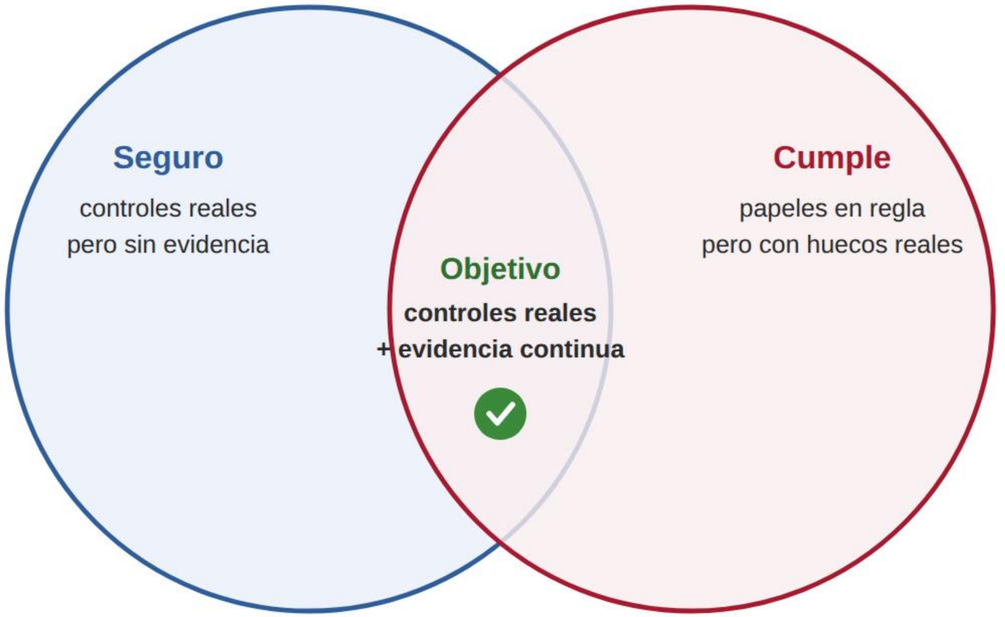
ISO/IEC 27001 · 27017 · 27018

demuestran un sistema de gestión

Leyes y regulación obligatorias

Ley 1581 de 2012 · Ley 1273 de 2009

su incumplimiento tiene sanciones



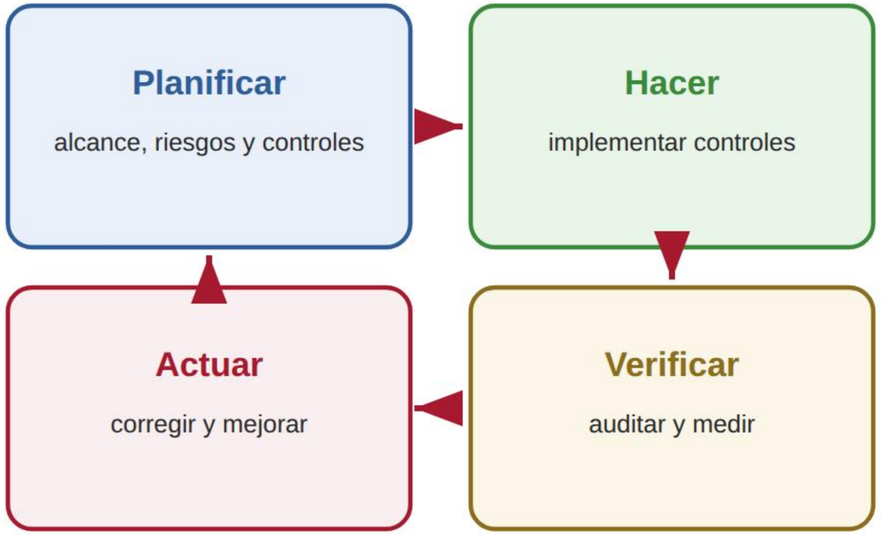
La visibilidad de la Parte 3 es la base

CloudTrail, Config y Security Hub producen la evidencia que piden los auditores.

Fuente: elaboración propia; Ley 1581 de 2012, ISO/IEC 27001:2022, AICPA SOC 2 y PCI SSC

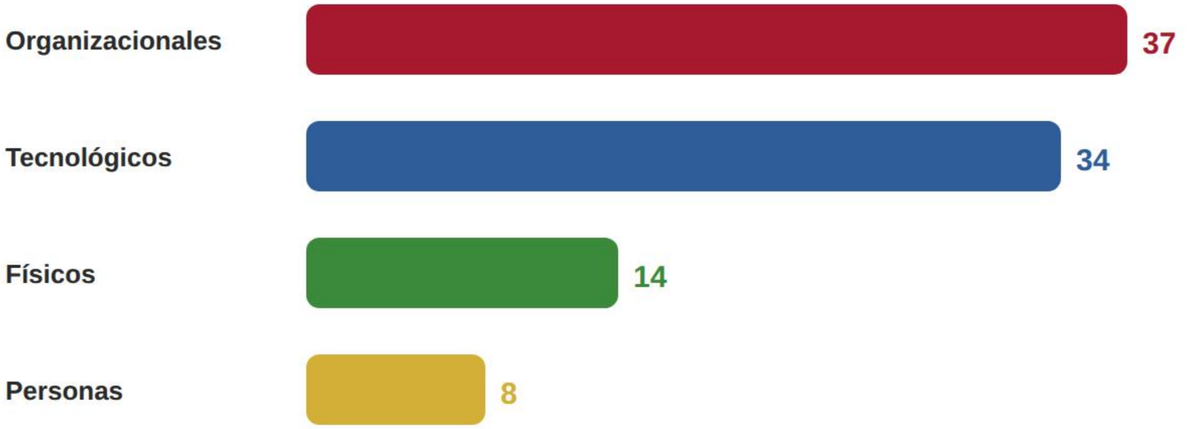
ISO/IEC 27001: un sistema de gestión de seguridad

Certifica que gestionas la seguridad con un ciclo de mejora continua y 93 controles de referencia.



Ciclo PDCA de mejora continua

Anexo A: 93 controles en 4 temas



Con 93 controles en total (versión 2022)

Camino de certificación

1. **Auditoría etapa 1 y 2** — organismo de certificación acreditado
2. **Certificado** — vigencia de 3 años
3. **Auditorías de seguimiento** — cada año
4. **Recertificación** — al cumplir el ciclo

En la nube: ISO/IEC 27017 (controles específicos de nube) · ISO/IEC 27018 (datos personales en nubes públicas)

Fuente: adaptado de ISO/IEC 27001:2022 (Anexo A) y AWS Compliance Programs

SOC 2: confianza demostrada por un auditor externo

Un contador público independiente evalúa tus controles frente a cinco criterios de servicio de confianza.

Seguridad

base obligatoria: protección contra acceso no autorizado

siempre incluido

Disponibilidad

el sistema responde según lo acordado

Integridad del procesamiento

el tratamiento es completo y exacto

Confidencialidad

la información restringida se protege

Privacidad

datos personales según lo prometido

Tipo I frente a tipo II

Tipo I
diseño

Una fecha concreta: ¿los controles están bien diseñados? (fotografía)

emitido por un auditor independiente · se comparte bajo confidencialidad

Tipo II
diseño + efectividad

Un periodo (por lo general 6 a 12 meses): ¿los controles funcionaron? (película)

mes 0 — 3 — 6 — 9 — 12

Fuente: adaptado de AICPA, Trust Services Criteria y guía de informes SOC 2

PCI DSS: si manejas tarjetas, doce requisitos

Es un estándar contractual de las marcas de tarjetas; aplica a quien almacena, procesa o transmite datos de cuenta.

Redes y sistemas seguros	1 Controles de seguridad de red	2 Configuraciones seguras
Proteger datos de cuenta	3 Proteger datos almacenados	4 Cifrar la transmisión en redes abiertas
Gestionar vulnerabilidades	5 Protección contra malware	6 Desarrollo y sistemas seguros
Controlar el acceso	7 Acceso por necesidad de saber	8 Identificar y autenticar (MFA) · 9 Acceso físico restringido
Monitorear y probar	10 Registrar y monitorear	11 Pruebas de seguridad regulares
Política de seguridad	12 Políticas y programa de seguridad	

Versión vigente: PCI DSS v4.0.1 · los íconos marcan requisitos que ya cubres con servicios vistos hoy

¿A quién aplica?

- Quien almacena, procesa o transmite datos de tarjeta
- Es contractual: lo exigen marcas y bancos adquirentes
- Niveles según el volumen de transacciones

Reducir el alcance

Si cobras en línea, usa una pasarela de pagos que reciba la tarjeta directamente.

Tu sistema nunca toca el dato y la auditoría se simplifica.

Fuente: adaptado de PCI Security Standards Council, PCI DSS v4.0.1: objetivos y requisitos

Qué certifica el proveedor y qué certificas tú

El proveedor cubre lo que opera; tu carga de trabajo debe demostrar lo que tú configuras.

HEREDADOS

los recibes del proveedor

- Controles físicos del centro de datos
- Controles ambientales: energía y enfriamiento
- Seguridad del hardware y del hipervisor

Los certificados del proveedor te respaldan

COMPARTIDOS

cada uno en su parte

- Gestión de parches: AWS la infraestructura, tú el sistema invitado
- Gestión de configuración: AWS sus equipos, tú tus sistemas
- Capacitación: AWS a su personal, tú al tuyo

Aporta tu evidencia y la del proveedor

DEL CLIENTE

dependen de cómo uses el servicio

- Seguridad de tus zonas y de tus redes virtuales
- Protección de tus comunicaciones y datos
- Identidades, accesos y registros de tu cuenta

Debes certificarlos tú

Usar un proveedor certificado no te certifica a ti

Te ahorra controles, pero no los elimina: tu alcance se audita aparte.

Fuente: adaptado de AWS, Modelo de responsabilidad compartida: controles heredados, compartidos y del cliente

EVIDENCIA

AWS Artifact y la evidencia para el auditor

Los informes y certificados del proveedor se descargan; la evidencia de tu parte la generas tú.

1 **Auditor o cliente**
pide pruebas de cumplimiento

2 **AWS Artifact**
portal de informes del proveedor

3 **Documentos del proveedor**
heredado: certificados y reportes

4 **Evidencia propia**
generada continuamente

5 **Informe final**
evidencia completa y ordenada

Del proveedor (lo heredado) · vía AWS Artifact

ISO/IEC 27001
certificado vigente

SOC 1, 2 y 3
informes del auditor, algunos tras acuerdo de confidencialidad

PCI DSS
atestado de cumplimiento del proveedor

De tu parte (lo que configuras)

AWS Config
recursos cumplen las reglas

Security Hub
postura contra estándares

CloudTrail
quién hizo qué, cuándo

Audit Manager
recolecta evidencia por marco

Fuente: adaptado de AWS Artifact, guía del usuario, y AWS Audit Manager

Ley 1581 de 2012: habeas data y sus protagonistas

El titular autoriza, el responsable decide el tratamiento y el proveedor cloud actúa como encargado.

Titular
dueño de los datos: cliente o empleado

→

Responsable
decide el tratamiento: la Corporación Industrial del Caribe

→

Encargado
trata los datos por cuenta del responsable: el proveedor cloud

Autorización → Responsable → contrato de transmisión → Encargado

Principios (art. 4)

- Legalidad
- Finalidad
- Libertad
- Veracidad
- Transparencia
- Acceso restringido
- **Seguridad**
- **Confidencialidad**

Seguridad y confidencialidad se cumplen con cifrado, IAM y registros

Derechos del titular (art. 8)

- Conocer, actualizar y rectificar
- Pedir prueba de la autorización
- Ser informado del uso de sus datos
- Revocar y solicitar la supresión
- Acceder gratis a sus datos
- Quejarse ante la SIC

Datos sensibles: autorización explícita y protección reforzada

Salud, origen étnico, orientación política, datos biométricos y datos de niños y adolescentes tienen reglas especiales.

Fuente: adaptado de la Ley 1581 de 2012 (arts. 4, 8, 17 y 18) y del Decreto 1377 de 2013, compilado en el Decreto 1074 de 2015

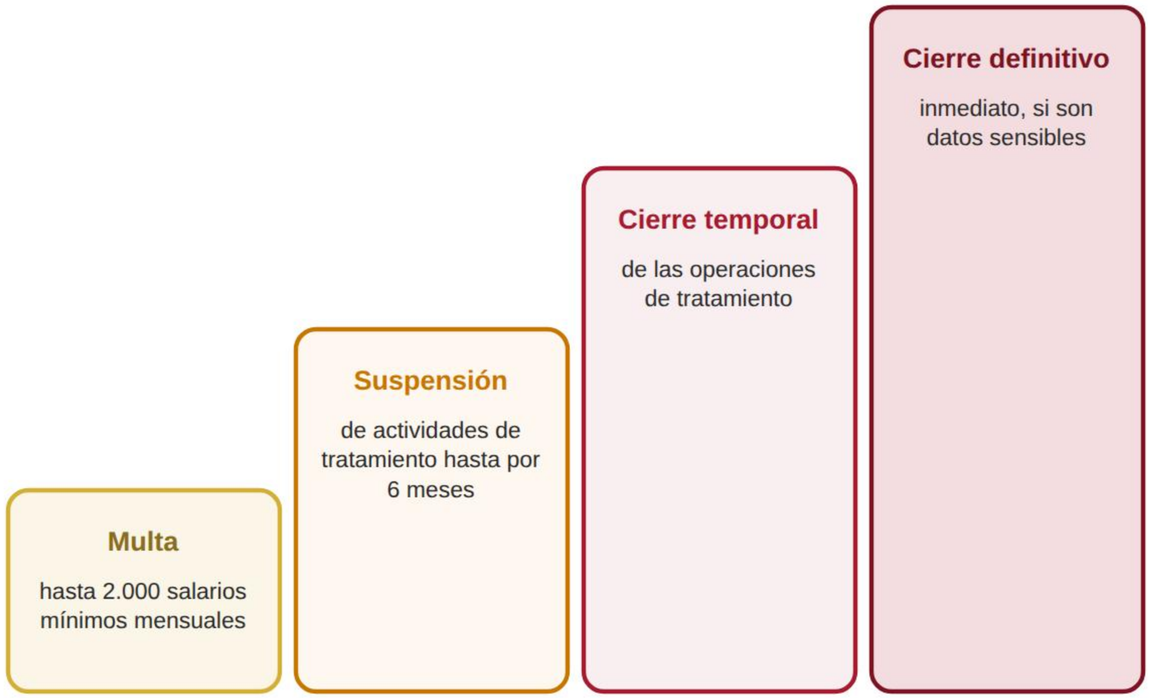
La SIC: autoridad, obligaciones y sanciones

La Superintendencia de Industria y Comercio vigila el cumplimiento y puede sancionar con multas y cierres.

Lo que la empresa debe tener listo

- **Política de tratamiento de datos** — publicada y conocida
- **Aviso de privacidad** — dice qué datos y para qué
- **Autorizaciones** — con prueba de que se otorgaron
- **Consultas y reclamos** — procedimiento con plazos
- **Registro de bases de datos (RNBD)** — cuando la empresa está obligada
- **Reporte de incidentes** — informar a la SIC violaciones de seguridad

Escalera de sanciones (art. 23)



Fuente: adaptado de la Ley 1581 de 2012 (arts. 17, 23 y 25), Decreto 886 de 2014 y SIC, Protección de datos personales

Transmisión y transferencia: no son lo mismo

Usar una región fuera de Colombia suele ser una transmisión a un encargado, bajo contrato.

Responsable
Corporación Industrial del Caribe

base de datos con datos personales

Colombia

TRANSMISIÓN · al encargado en el exterior

contrato →

Región de AWS
proveedor como encargado

- Contrato de transmisión: alcance y finalidad
- Obligaciones de seguridad para el encargado
- Sin nueva autorización del titular si se cumple el contrato

TRANSFERENCIA · a otro responsable en el exterior

entrega →

Otro responsable
p. ej. empresa vinculada

Regla general (art. 26): prohibida hacia países sin nivel adecuado

- Excepción: autorización expresa del titular
- Excepción: necesaria para ejecutar un contrato
- La SIC publica la lista de países con nivel adecuado

Fuente: adaptado de la Ley 1581 de 2012 (art. 26), Decreto 1377 de 2013 (arts. 24 y 25) y SIC, Circular Externa 005 de 2017

RESIDENCIA DE DATOS

Elegir región: legal, técnica y económica

La región es una decisión de cumplimiento; se hace cumplir con controles, no con buenas intenciones.

Criterios, en orden

1 Legal y contractual
¿hay límites de residencia?

2 Servicios disponibles
¿tiene lo que necesitas?

3 Latencia
distancia a tus usuarios

4 Costo
varía según la región

5 Resiliencia
mínimo dos zonas

Candidatas cercanas



São Paulo
`sa-east-1`
la más cercana en Sudamérica; suele costar más que Virginia



Norte de Virginia
`us-east-1`
la que más servicios ofrece y precios habitualmente bajos



México (centro)
`mx-central-1`
región reciente: verifica el catálogo de servicios

Cómo se hace cumplir



SCP en Organizations
niega las regiones no aprobadas



Claves de KMS regionales
el material no viaja entre regiones



Replicación entre regiones
solo si se evalúa y se aprueba

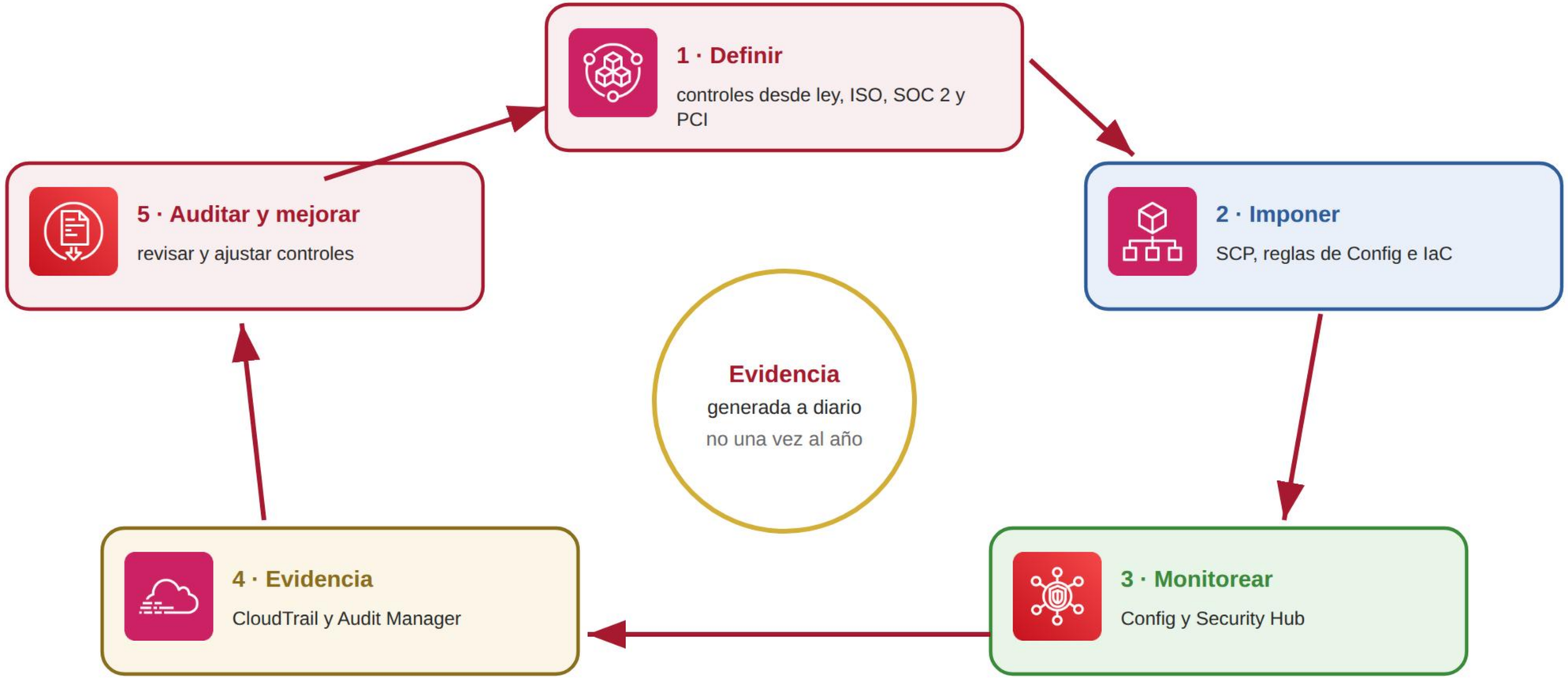


Config y documentación
registro de cada decisión

Fuente: adaptado de AWS, Choosing the right AWS Region y AWS Organizations, políticas de control de servicios (SCP)

Cumplimiento como ciclo, no como evento anual

Se definen controles, se imponen como guardarraíles, se monitorean y se guarda la evidencia a diario.

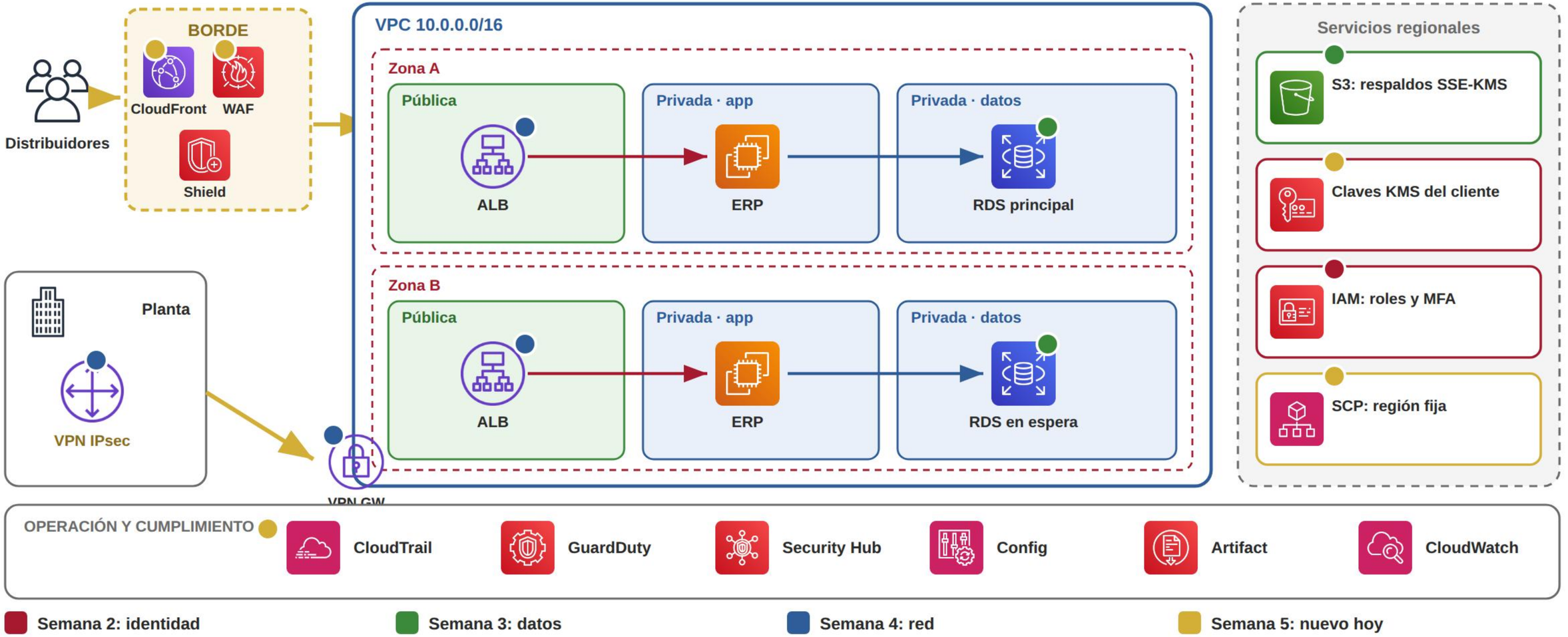


Si la SIC o un auditor pregunta qué medidas tenías en una fecha dada, los registros responden.

Fuente: adaptado de AWS Audit Manager, AWS Config conformance packs y AWS Control Tower

Corporación Industrial del Caribe: la arquitectura completa

Identidad, datos, red y seguridad de las cinco semanas, reunidos en una sola arquitectura con evidencia.



Fuente: caso del curso; adaptado de AWS Architecture Center y AWS Security Reference Architecture

MAPA DE LA UNIDAD 1

Unidad 1 en un mapa, rumbo al Parcial 1

Cada semana se apoya en la anterior: vocabulario, identidad, datos, red y, al final, protección y cumplimiento.

Semana 1

Fundamentos

- ¿Qué diferencia IaaS, PaaS y SaaS?
- ¿Qué es Well-Architected?

Semana 2

Despliegue e identidad

- Nube pública, privada e híbrida
- ¿Cómo funciona IAM y el mínimo privilegio?

Semana 3

Almacenamiento

- Objetos, bloques y archivos
- Durabilidad y cifrado

Semana 4

Redes virtuales

- VPC, subredes públicas y privadas
- Security Groups y NACL

Semana 5

Seguridad y cumplimiento

- Responsabilidad compartida y capas
- Cifrado, KMS, registros y la Ley 1581

Semana 6 · Repaso de la Unidad 1 y Parcial 1 (20 % de la rúbrica)

Practica explicando la arquitectura de la Corporación con la matriz de responsabilidad compartida a la mano.

Fuente: calendario del curso Arquitectura en la Nube 2026-2 (Unidad 1)

CIERRE DE LA SEMANA

Semana 5 en cuatro ideas

La seguridad no es un producto que se compra: es una disciplina de diseño que se demuestra.

1



Responsabilidad compartida

El proveedor asegura la nube; tú, lo que pones en ella; defensa en capas

2



Cifrado y claves

TLS, AES-256, KMS, cifrado de sobre y secretos fuera del código

3



Ver y filtrar

CloudTrail, CloudWatch, GuardDuty, WAF, Shield y Security Hub

4



Cumplir y demostrar

ISO 27001, SOC 2, PCI DSS, Ley 1581 y elección de región

Para llevar: la seguridad no se instala, se diseña en cada decisión

Siguiente: Semana 6 · Repaso de la Unidad 1 y Parcial 1. Después, Unidad 2: cómputo en la nube.

 **Semana 2**

 **Semana 3**

 **Semana 4**

 **Semana 5**

Fuente: elaboración propia